Studio Nx

AI 구현 설명 19 — 비밀번호 변경 · 회원 탈퇴 API 템플릿

2026-10-18

AI 구현 설명 19 — 비밀번호 변경 · 회원 탈퇴 API 템플릿

항목	내용
작성	Claude (AI)
작성일	2026-10-03
작업	P1-09 비밀번호 변경, 회원 탈퇴(재확인, 소프트 삭제, 로그인 차단) (**템플릿**), 이전 문서: 18_user_profile_api_template.md
브랜치	`feature/phase1/p1-09-password-withdraw` (P1-08 브랜치에서 갈라졌으므로 **P1-04, 05, 08 PR을 먼저 병합**해야 합니다)
원칙	백엔드는 **템플릿만** 만들었습니다 (라우터, 스키마, 함수 이름과 TODO). 실제 구현은 사용자가 합니다

---

1. 무엇을 만들었나

파일	상태	내용
`app/api/v1/users.py`	템플릿 추가	`PUT /users/me/password`와 `DELETE /users/me` 입니다 (둘 다 성공하면 204)
`app/schemas/user.py`	완성해서 추가	`PasswordChangeRequest {current_password, new_password}`와 `WithdrawRequest {password}` 입니다
`app/services/user_service.py`	템플릿 추가	`check_current_password`, `change_password`, `withdraw`
`app/core/errors.py`	수정	`WRONG_PASSWORD`(400)를 추가했습니다
`tests/test_user_routes.py`	완성해서 추가	두 주소의 연결을 확인합니다

2. 왜 이렇게 했나

2.1 비밀번호가 틀리면 401이 아니라 400

상황	응답	이유
로그인 모달에서 틀림	401 `INVALID_CREDENTIALS`	로그인하기 전이라서 인증 실패가 맞습니다
로그인한 뒤 재확인에서 틀림	400 `WRONG_PASSWORD`	화면(`api.js`)은 401을 받으면 토큰 재발급을 시도합니다. 토큰은 멀쩡하므로 401을 쓰면 재발급한 뒤 같은 요청을 다시 보내게 됩니다

2.2 탈퇴 처리 (FR-108)

단계	내용
재확인	`check_current_password`
소프트 삭제	`status = 'DELETED'`, `deleted_at = 지금`으로 바꾸고 행은 남깁니다 (프로젝트와 문의 기록에 연결되어 있기 때문입니다)
로그인 차단	`authenticate`, `get_current_user`, `get_active_user`가 모두 `ACTIVE`만 통과시키므로 추가 작업이 필요 없습니다

단계	내용
쿠키	라우터에서 `clear_refresh_cookie` (P1-05)

2.3 사용자 결정 (2026-10-03)

항목	결정	템플릿 반영
같은 이메일과 닉네임으로 다시 가입	**탈퇴한 지 3일 뒤부터 가능**하고, 그 전에는 다시 쓸 수 있는 날짜를 안내합니다	탈퇴할 때는 값을 그대로 둡니다. 가입과 중복 확인에서 3일 안이면 409 `REJOIN_TOO_SOON`이고, 3일이 지났으면 `release_withdrawn`이 예전 행의 값을 비웁니다 (P1-04, 16 §2.4)
내가 OWNER인 프로젝트	**남겨 둡니다**	`withdraw`는 `projects`를 건드리지 않습니다
프로필 사진 파일	탈퇴할 때 삭제합니다	`delete_profile_image`를 다시 씁니다

> 기다리는 기간 3일은 `auth_service.REJOIN_WAIT_DAYS` 한 곳에서 바꿉니다. PRD 01 FR-108에도 반영했습니다.

3. 검증 결과 (2026-10-03)

확인	결과
`pytest`	10개가 통과했습니다
`ruff check`	통과했습니다
OpenAPI	`PUT /users/me/password`, `DELETE /users/me`가 표시됩니다

4. 남은 일 (사용자)

순서	할 일	파일
1	서비스 함수 3개	`app/services/user_service.py`
2	라우터 본문 2개	`app/api/v1/users.py`
3	화면 연결 (`initPasswordForm`, `initWithdrawForm`)	`static/js/pages/userinfo.js`
4	테스트: 탈퇴한 계정으로 로그인하면 실패하는지, 3일 안에 다시 가입하면 409인지 확인 (P1-18)	`tests/`

5. 자주 받을 질문 대비

- **Q. DELETE 요청에 본문을 넣어도 되나요?** HTTP 규칙상 금지되지는 않고, FastAPI도 받습니다. 비밀번호를 주소(쿼리)에 넣으면 서버 로그에 남을 수 있어 본문으로 받습니다.
- **Q. 왜 행을 지우지 않나요?** 프로젝트·문의·협업 기록이 `user_id`로 연결되어 있어, 지우면 기록이 끊기거나 함께 지워집니다 (DB.md §4 삭제 정책).
- **Q. 비밀번호를 바꾸면 다른 기기도 로그아웃되나요?** 지금은 아닙니다. 리프레시 토큰을 DB에 두지 않기 때문입니다 (17 §2.4).